Tabla 2. Catálogo de controles de hardening evaluados

Explicación. Documenta el instrumento de medición y la transparencia del mapeo. La tabla distingue los controles con referencia CIS contrastada de los controles internos inspirados en buenas prácticas. Esta separación evita atribuir al estándar CIS resultados que la plataforma calcula con controles propios y permite reproducir el alcance del estudio.

Descripción. Una fila por control. «Referencia CIS» indica el identificador del benchmark cuando el mapeo fue verificado; «Mapeo» señala si el control es CIS oficial o interno. «Nivel» resume el perfil del benchmark (N1/N2) y «Propósito» resume el requisito evaluado.

Fuente y notas. Fuente: Dataset sintético reproducible; catálogo de 14 controles activos. La referencia CIS se contrastó con CIS Ubuntu Linux 22.04 LTS Benchmark v1.0.0. Los controles internos no constituyen un mapeo oficial de CIS.

Código	Referencia CIS	Control	Categoría	Severidad	Nivel	Mapeo	Propósito
SSH-EMPTY	5.2.9	SSH rechaza contraseñas vacías	Acceso remoto	Alta	N1	CIS oficial	PermitEmptyPasswords debe estar deshabilitado.…
SSH-KEYONLY	—	SSH prefiere autenticación por clave pública	Acceso remoto	Media	—	Interno	Control interno inspirado en buenas prácticas: PasswordAuthentication debería estar deshabilitado cuando exista un despliegue de claves gestionado.…
SSH-MAXAUTH	5.2.18	SSH limita los intentos de autenticación	Acceso remoto	Media	N1	CIS oficial	MaxAuthTries debe ser 4 o menos para limitar intentos fallidos por conexión.…
SSH-ROOT	5.2.7	Acceso SSH directo de root deshabilitado	Acceso remoto	Alta	N1	CIS oficial	El servicio SSH no debe permitir autenticación directa del usuario root. La administración debe realizarse con cuentas nominativas y escalada controlada.…
UPDATES	1.9	Actualizaciones y parches de seguridad instalados	Actualizaciones	Alta	N1	CIS oficial	No deben existir actualizaciones pendientes en el sistema auditado. La comprobación automatizada revisa paquetes actualizables.…
AUTH-FAILLOCK	5.4.2	Bloqueo de cuentas por intentos fallidos	Autenticación	Alta	N1	CIS oficial	Debe existir una política de bloqueo temporal tras intentos fallidos (pam_faillock o mecanismo equivalente).…
AUTH-PWQUALITY	5.4.1	Requisitos de complejidad de contraseñas	Autenticación	Alta	N1	CIS oficial	La política de creación de contraseñas debe exigir al menos 14 caracteres y complejidad razonable mediante pam_pwquality.…
FW-DEFAULT	3.5.1.7	Política por defecto del firewall: denegar entrada	Firewall	Alta	N1	CIS oficial	UFW debe aplicar una política por defecto de denegación para tráfico entrante.…
FW-ENABLED	3.5.1.3	Firewall UFW habilitado	Firewall	Alta	N1	CIS oficial	El servicio UFW debe estar habilitado y activo.…
ASLR	1.5.1	Aleatorización del espacio de direcciones (ASLR)	Hardening del kernel	Media	N1	CIS oficial	kernel.randomize_va_space debe valer 2.…
SHADOW-PERMS	6.1.5	Permisos restrictivos sobre /etc/shadow	Permisos de archivos	Alta	N1	CIS oficial	El archivo /etc/shadow debe pertenecer a root:shadow y tener modo 640 o más restrictivo.…
AUDITD	4.1.1.2	auditd habilitado y activo	Registro de eventos	Media	N2	CIS oficial	El servicio auditd debe estar habilitado y en ejecución.…
LOGGING	4.2.2.2	Servicio de registro rsyslog habilitado	Registro de eventos	Media	N1	CIS oficial	rsyslog debe estar instalado y su servicio habilitado/activo.…
SERVICES	—	Servicios de red innecesarios deshabilitados	Servicios	Media	—	Interno	Control interno: revisar servicios heredados o de compartición que no correspondan al propósito del servidor (telnet, rsh, xinetd, tftp, etc.).…